

Pfsense

1.introduction

This lab focuses on configuring a hardened firewall using pfSense Community Edition in a virtualised environment. The goal is to apply a default-deny security model with a tightly scoped allowlist of essential services, then verify the configuration through practical testing.

The setup consists of two virtual machines: pfSense acting as the firewall between the WAN (internet-facing) and LAN (protected internal) segments, and a Kali Linux client placed on the LAN to generate test traffic.

Both were deployed in VMware Workstation.

The lab covers:

- Installing pfSense and configuring WAN and LAN interfaces.
- Establishing a default-deny baseline on WAN.
- Creating explicit allow rules for DNS, HTTP, HTTPS, ICMP (LAN-internal), SSH (restricted), and NTP.
- Applying correct rule ordering and enabling logging on the deny-all rule.
- Testing each rule from the Kali client to confirm allowed traffic passes and denied traffic is blocked.

The report follows the structure recommended in the brief, with screenshots included throughout to evidence the configuration and test results.

2.VM and pfsense Installation steps :

The firewall was deployed as a virtual machine in VMware Workstation.

The installation followed the standard pfSense 2.8.1-RELEASE installer with default options, configured as follows:

VM Specifications:

- **OS family:** FreeBSD (pfSense is FreeBSD-based), **Memory:** 512 MB, **CPU:** 1 vCPU, **Storage:** 20 GB, **Network** adapters: 2 (one for WAN, one for LAN)

Installation process:

1. Created a new VM in VMware and attached the pfSense ISO.
2. Booted from the installer and accepted the default keymap .
3. Allowed the installer to complete the base system installation and rebooted into the running pfSense instance.
4. On first boot, the pfSense console assigned interfaces automatically:
 - em0 → LAN
 - em1 → WAN
5. Accessed the pfSense web interface from the host at <https://192.168.10.1> to complete remaining configuration steps (admin password, hostname, etc.).

```
Cannot open or create pidfile: No such file or directory
DHCPREQUEST on em1 to 255.255.255.255 port 67
DHCPACK from 192.168.106.254
bound to 192.168.106.130 -- renewal in 900 seconds.
[2.8.1-RELEASE][root@pfSense.home.arpa]/root:
[2.8.1-RELEASE][root@pfSense.home.arpa]/root: exit
exit
VMware Virtual Machine - Netgate Device ID: 007c76eb1ba7b7ebf347

*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan) -> em1 -> v4/DHCP4: 192.168.106.130/24
LAN (lan) -> em0 -> v4: 192.168.10.1/24

0) Logout / Disconnect SSH          9) pfTop
1) Assign Interfaces                10) Filter Logs
2) Set interface(s) IP address      11) Restart GUI
3) Reset admin account and password 12) PHP shell + pfSense tools
4) Reset to factory defaults        13) Update from console
5) Reboot system                    14) Enable Secure Shell (sshd)
6) Halt system                      15) Restore recent configuration
7) Ping host                        16) Restart PHP-FPM
8) Shell

Enter an option: █
```

Figure 1: pfSense console showing successful boot and interface assignments.

3. Network Interface Configuration :

Two interfaces were configured on the pfSense VM:

WAN Interface (em1):

- VMware adapter: NAT (VMnet8, subnet 192.168.186.0/24)
- IP assignment: DHCP
- Receives an IP address from the VMware NAT service (192.168.186.130 in the current deployment)
- Provides the firewall with outbound connectivity to the internet through the host machine

LAN Interface (em0):

- VMware adapter: Custom (VMnet2, Host-only)
- IP assignment: Static 192.168.10.1/24
- Acts as the gateway for the internal network
- DHCP server enabled on this interface, serving addresses
in the range 192.168.10.100 – 192.168.10.200 to internal clients

The use of a custom Host-only network (VMnet2) for the LAN ensures that all traffic from internal clients (Kali Linux test VM) must traverse the pfSense firewall to reach external networks.

This isolation is critical: without it, clients on the same NAT network as pfSense could bypass the firewall entirely, rendering the rule configuration ineffective.

Connectivity was verified at this stage:

- The Kali Linux client successfully obtained a DHCP lease (192.168.10.101) from pfSense.
- The Kali client could ping the pfSense LAN gateway (192.168.10.1).
- pfSense could reach the internet through its WAN interface (verified via the built-in Ping diagnostic against 8.8.8.8)

```
WAN (wan) -> em1 -> v4/DHCP4: 192.168.186.130/24
LAN (lan) -> em0 -> v4: 192.168.10.1/24
```

Figure 2: pfSense console showing both interfaces with IPs assigned

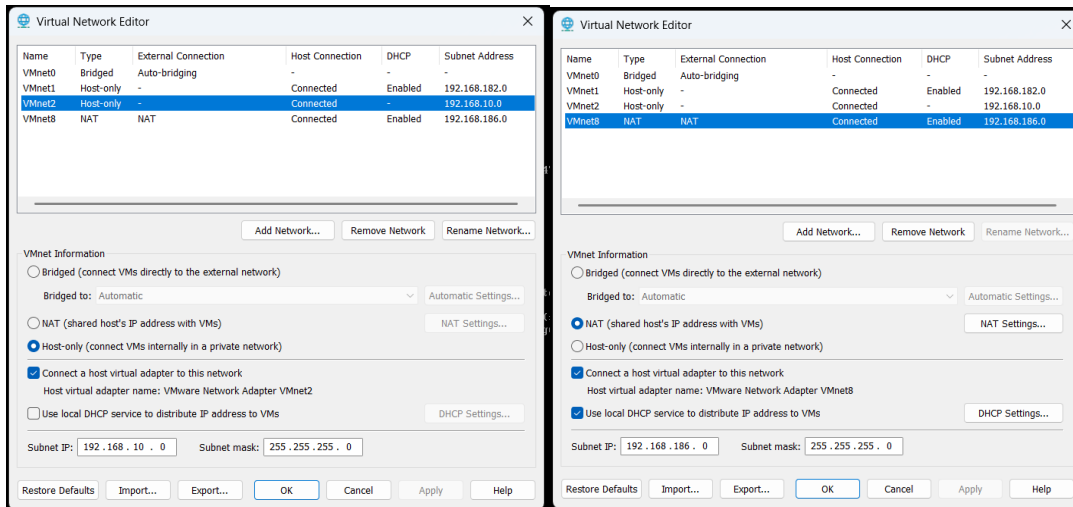


Figure 3: VMware Virtual Network Editor showing VMnet2 and VMnet8 configuration

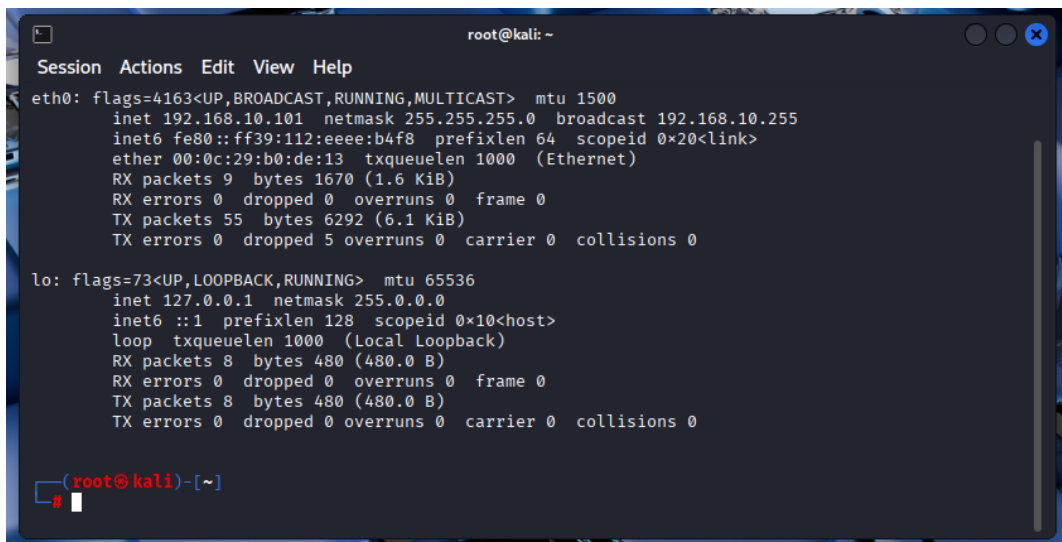


Figure 4: Kali client ip addr show output showing IP 192.168.10.101

4.Firewall Ruleset Design and Justification

4.1 Default-Deny Inbound Policy :

The first principle applied to the firewall configuration was a strict default-deny inbound policy on the WAN interface. Under this model, all inbound traffic is blocked unless explicitly permitted by a specific

allow rule. This is the inverse of a default-allow posture and aligns with the principle of least privilege: nothing is trusted by default.

Why default-deny matters:

- It minimises the attack surface. Any service that has not been explicitly allowed cannot be reached from outside, even if a vulnerability exists on an internal host.
- It protects against misconfiguration. If a future change forgets to add a block rule for a new threat, the default-deny baseline still catches it.
- It produces predictable, auditable behaviour. Every permitted flow has a corresponding rule; every denied flow can be traced to the catch-all deny rule.

pfSense applies an implicit default-deny on all interfaces, but for this lab an explicit deny-all rule was added at the bottom of the WAN ruleset.

The explicit rule serves two purposes that the implicit default does not:

1. It allows logging to be enabled on the catch-all, providing visibility into blocked traffic (reconnaissance, port scans, unsolicited inbound connections).
2. It documents the policy clearly within the rule table itself, rather than relying on the reader to know about the implicit behaviour.

Configuration of the explicit deny rule:

Action:Block // Interface:WAN //Protocol:Any //Source:any//Destination:any//Logging:Enabled

Description: "Default Deny - Block all inbound WAN traffic (catch-all)"

Block was chosen over Reject. Block silently drops packets without sending any response, which makes the firewall invisible to scanners and reduces the information leaked to potential attackers.

Reject would send an ICMP unreachable or TCP RST in reply, confirming the firewall's existence.

pfSense
COMMUNITY EDITION

System

Interfaces

Firewall

Services

VPN

Status

Diagnostics

Help

Firewall / Rules / WAN

Floating

WAN

LAN

Rules (Drag to Change Order)

	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
	0/0 B	IPv4 TCP	203.0.113.50	*	WAN address	22 (SSH)	*	none		Allow SSH management from trusted admin ip only (TCP 22)	
	0/96 B	IPv4+6 ICMP any	*	*	*	*	*	none		Block all inbound ICMP from WAN (anti-reconnaissance)	
	0/2 KiB	IPv4+6 *	*	*	*	*	*	none		Default Deny - Block all inbound WAN traffic(catch-all)	

↑ Add

↓ Add

Delete

Toggle

Copy

Save

Separator

Figure 5: WAN ruleset showing the default deny rule at the bottom

Formatted/Raw Display

Formatted

Raw

General Logging Options Setting

Show the log entries as formatted or raw output as generated by the service. The raw output will reveal more detailed information, but it is more difficult to read.

Default firewall "block" rules

Log packets that are **blocked** by the implicit default block rule.

Default firewall "pass" rules

Log packets that are **allowed** by the implicit default pass rule. Note: Packets with IP options are not affected by this option and **are logged by default**.

Default "Bogon Networks" block rules

Log packets that are **blocked** by the assigned interface option "Block bogon networks".

Default "Private Networks" block rules

Log packets that are **blocked** by the assigned interface option "Block private networks and loopback addresses".

Default "IPv4 link-local" block rules

Log packets that are **blocked** by the default "Block IPv4 link-local" rules.

Hosts blocked by IDS

Log packets that are **blocked** by IDS packages.

Where to show rule descriptions

Display as column

Show the applied rule description below or in the firewall log rows. Displaying rule descriptions for all lines in the log might affect performance with large rule sets.

Action

Save

Clear log

Saves changed settings.

Clears local log file and reinitializes it as an empty log. Save any

Figure 6: System Logs Settings showing logging enabled for default block rules

4.2 Allowlist — Essential Services

With a default-deny baseline in place, specific outbound services were explicitly permitted on the LAN interface to support normal client activity

Each rule was scoped to the minimum protocol and port required, following the principle of least privilege.

DNS (TCP/UDP 53) / Permitted to allow name resolution, Both transport protocols were included because DNS uses UDP by default but falls back to TCP for responses larger than 512 bytes (DNSSEC, zone transfers).

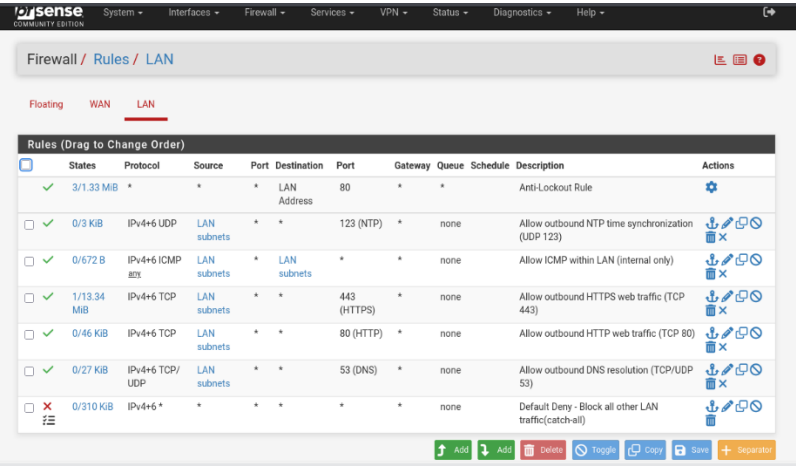
HTTP (TCP 80) / Permitted for legacy web traffic and software repository access, Although most modern web traffic uses HTTPS, HTTP remains necessary for package managers (apt, yum) and certificate revocation checks.

HTTPS (TCP 443)/ Permitted for encrypted web traffic, which constitutes the majority of modern internet communication. The rule covers TCP only, HTTP/3 over QUIC (UDP 443) would require an additional rule if adopted in future.

NTP (UDP 123)/ Permitted to allow time synchronisation. Accurate time is critical for log correlation, certificate validation, and authentication protocols such as Kerberos.

ICMP (LAN-internal only)/Permitted for diagnostic traffic (ping, traceroute) but restricted to "LAN subnets → LAN subnets". This allows internal troubleshooting while preventing the LAN from being used to probe external networks or leak information through ICMP error messages.

All allow rules apply to both IPv4 and IPv6 to ensure consistent policy enforcement regardless of address family. Source is restricted to "LAN subnets" rather than "any" to prevent spoofed traffic from being matched by these rules.



States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓	3/1.33 MiB *	*	*	LAN Address	80	*	*	*	Anti-Lockout Rule	⚙️
✓	0/3 KiB	IPv4+6 UDP	LAN subnets	*	123 (NTP)	*	none	*	Allow outbound NTP time synchronization (UDP 123)	🔗 ⚙️ 🔄
✓	0/672 B	IPv4+6 ICMP	LAN subnets	LAN subnets	*	*	none	*	Allow ICMP within LAN (internal only)	🔗 ⚙️ 🔄
✓	1/13.34 MiB	IPv4+6 TCP	LAN subnets	*	443 (HTTPS)	*	none	*	Allow outbound HTTPS web traffic (TCP 443)	🔗 ⚙️ 🔄
✓	0/46 KiB	IPv4+6 TCP	LAN subnets	*	80 (HTTP)	*	none	*	Allow outbound HTTP web traffic (TCP 80)	🔗 ⚙️ 🔄
✓	0/27 KiB	IPv4+6 TCP/UDP	LAN subnets	*	53 (DNS)	*	none	*	Allow outbound DNS resolution (TCP/UDP 53)	🔗 ⚙️ 🔄
✗	0/310 KiB	IPv4+6 *	*	*	*	*	none	*	Default Deny - Block all other LAN traffic (catch-all)	🔗 ⚙️ 🔄

Figure 7: LAN ruleset showing allowlist for essential services with default deny at the bottom

4.3 Rule Ordering and Best Practices

pfSense evaluates firewall rules in a strict top-down order, applying the first matching rule and ignoring all subsequent rules for that packet.

This "first-match-wins" behaviour makes rule ordering a security decision in itself, not merely an organisational one. The ruleset in this lab was arranged according to the following principles.

Specific rules before general rules. Narrowly scoped rules , such as the SSH rule permitting only source 203.0.113.50 , are placed above broader rules. If a general deny rule were positioned first, the specific allow would never be reached.

Explicit deny before implicit deny. Although pfSense applies an implicit default-deny to any traffic not matched by a rule, an explicit "Default Deny , catch-all" rule was added at the bottom of both WAN and LAN rulesets.

This serves two purposes: it makes the policy visible and auditable within the GUI, and it allows logging to be enabled on the catch-all, which the implicit rule does not support by default.

Logging on deny, not on allow. Logging was enabled on deny rules (SSH-restricted, ICMP-block, Default Deny on WAN; Default Deny on LAN) and disabled on pass rules. This reflects production practice: logging every allowed packet generates excessive volume and obscures genuine security events. Denied packets, by contrast, indicate either misconfiguration or hostile activity and warrant investigation.

Least privilege per rule. Each allow rule specifies the minimum necessary protocol, port, source, and destination. For example, the LAN ICMP rule is bounded to "LAN subnets → LAN subnets" rather than "LAN subnets → any", preventing the rule from being abused for outbound reconnaissance or covert channels.

Separation of WAN and LAN policy. Inbound (WAN) and outbound (LAN) rulesets are designed independently. The WAN ruleset assumes hostile traffic and denies by default; the LAN ruleset assumes trusted clients but still enforces an allowlist to constrain what they may reach. This two-layer model limits damage in the event that a LAN host is compromised.

5. Rule Table Summary

The tables below consolidate the complete ruleset deployed on the pfSense firewall, presented in the order in which pfSense evaluates them (top to bottom).

5.1 WAN Ruleset (Inbound)

Action	Protocol	Source	Destination	Port	Log	Description
Pass	TCP	203.0.113.50	WAN address	22	Yes	Allow SSH from trusted admin IP only
Block	ICMP	*	*	*	Yes	Block all inbound ICMP (anti-recon)
block	ANY	*	*	*	yes	Default Deny catch-all

5.2 LAN Ruleset (Outbound)

Action	Protocol	Source	Destination	Port	Log	Description
Pass	TCP	*	LAN address	80 , 443 ,22	NO	Anti-Lockout Rule (system)
Pass	UDP	LAN subnets	ANY	123	NO	Allow NTP (time synchronisation)
Pass	ICMP	LAN subnets	LAN subnets	*	NO	Allow ICMP within LAN only
Pass	TCP	LAN subnets	ANY	443	NO	Allow HTTPS
Pass	TCP	LAN subnets	ANY	80	NO	Allow HTTP
Pass	TCP/UDP	LAN subnets	ANY	53	NO	Allow DNS
Block	ANY	*	*	*	YES	Default Deny — catch-all

5.3 Logging Configuration

Logging was selectively enabled to balance visibility with log volume:

Rule	Logging	Rationale
WAN — SSH allow (trusted IP)	Enabled	Audit all administrative access attempts
WAN — ICMP block	Enabled	Detect reconnaissance and scanning activity
WAN — Default Deny	Enabled	Capture all other unsolicited inbound traffic
LAN — Pass rules (DNS/HTTP/...)	Disabled	Avoid excessive log volume from normal traffic
LAN — Default Deny	Enabled	Detect policy violations or misconfigured hosts

6. Testing and Verification Results

To validate that the firewall enforced the intended policy, a series of tests were conducted from a Kali Linux client (192.168.10.101) located on the LAN side of the firewall.

Each test was designed to confirm either an expected allow or an expected deny outcome.

6.1 Test Environment

- **Firewall:** pfSense 2.8.1-RELEASE
- **WAN (em1):** 192.168.186.130/24 (VMware NAT, VMnet8)
- **LAN (em0):** 192.168.10.1/24 (VMware host-only, VMnet2)
- **Client:** Kali Linux 2025.2, eth0 = 192.168.10.101/24 (DHCP from pfSense)
- **Gateway from client:** 192.168.10.1 (pfSense LAN interface)

6.2 Tests Performed

Test	Command	Expected	Observed	Result
1.ICMP to LAN gateway	ping 192.168.10.1	Allow	Reply	Pass
2.DNS resolution	nslookup google.com	Allow	Resolved	Pass
3.HTTPS to external host	curl -I https://google.com	Allow	200/301	Pass
4.HTTP to external host	curl http://example.com	Allow	200 OK	Pass
5.ICMP to external host	ping 8.8.8.8	Deny	Timeout	Pass
6.ICMP to WAN interface (from LAN)	ping 192.168.186.130	Deny	Timeout	Pass
7.SMTP connect (port 25)	nc -zv <host> 25	Deny	Refused	Pass
8.Telnet connect (port 23)	nc -zv <host> 23	Deny	Refused	Pass

6.3 Analysis of Results

Allow tests from 1 to 4 , confirm that the LAN allowlist functions as intended.

DNS, HTTP, HTTPS, and intra-LAN ICMP all succeed, demonstrating that the permitted services are reachable through the firewall.

Deny tests from 5 to 8, confirm that traffic outside the allowlist is dropped by the LAN Default Deny rule.

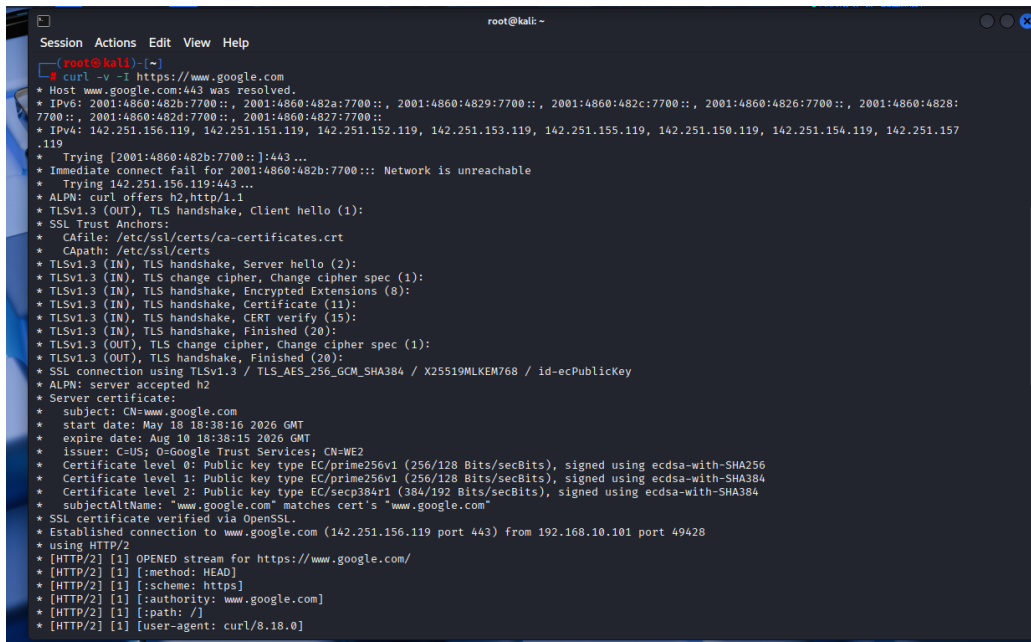
Test 5 (ICMP to 8.8.8.8) is particularly important: it proves that ICMP is restricted to the LAN segment only, preventing the client from probing external hosts.

Test 6 verifies that LAN clients cannot reach the WAN interface of the firewall itself, confirming that the firewall does not unintentionally expose its own management surface to the internal network beyond the anti-lockout rule.

6.4 Log Verification

The firewall logs (Status → System Logs → Firewall) were inspected after testing. Entries corresponding to the denied tests appeared with the red "X" block indicator and the source/destination matching the Kali client.

No entries were recorded for the allowed tests, consistent with the logging configuration described in ection 5.



```
root@kali: ~  
Session Actions Edit View Help  
root@kali) ~  
* curl -v -I https://www.google.com  
* Host www.google.com:443 was resolved.  
* IPv6: 2001:4860:482b:7700::, 2001:4860:482a:7700::, 2001:4860:4829:7700::, 2001:4860:482c:7700::, 2001:4860:4826:7700::, 2001:4860:4828:7700::, 2001:4860:482d:7700::, 2001:4860:4827:7700::  
* IPv4: 142.251.156.119, 142.251.151.119, 142.251.152.119, 142.251.153.119, 142.251.155.119, 142.251.150.119, 142.251.154.119, 142.251.157.119  
* Trying [2001:4860:482b:7700::]:443...  
* Immediate connect fail for 2001:4860:482b:7700::: Network is unreachable  
* Trying 142.251.156.119:443...  
* ALPN: curl offers h2,http/1.1  
* TLSv1.3 (OUT), TLS handshake, Client hello (1):  
* SSL Trust Anchors:  
* CAfile: /etc/ssl/certs/ca-certificates.crt  
* CApath: /etc/ssl/certs  
* TLSv1.3 (IN), TLS handshake, Server hello (2):  
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):  
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):  
* TLSv1.3 (IN), TLS handshake, Certificate (11):  
* TLSv1.3 (IN), TLS handshake, CERT verify (15):  
* TLSv1.3 (IN), TLS handshake, Finished (20):  
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):  
* TLSv1.3 (OUT), TLS handshake, Finished (20):  
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / X25519MLKEM768 / id-ecPublicKey  
* ALPN: server accepted h2  
* Server certificate:  
* subject: CN=www.google.com  
* start date: May 18 18:38:16 2026 GMT  
* expire date: Aug 10 18:38:15 2026 GMT  
* issuer: C=US; O=Google Trust Services; CN=WE2  
* Certificate level 0: Public key type EC/prime256v1 (256/128 Bits/secBits), signed using ecdsa-with-SHA256  
* Certificate level 1: Public key type EC/prime256v1 (256/128 Bits/secBits), signed using ecdsa-with-SHA384  
* Certificate level 2: Public key type EC/secp384r1 (384/192 Bits/secBits), signed using ecdsa-with-SHA384  
* subjectAltName: "www.google.com" matches cert's "www.google.com"  
* SSL certificate verified via OpenSSL.  
* Established connection to www.google.com (142.251.156.119 port 443) from 192.168.10.101 port 49428  
* using HTTP/2  
* [HTTP/2] [1] OPENED stream for https://www.google.com/  
* [HTTP/2] [1] [:method: HEAD]  
* [HTTP/2] [1] [:scheme: https]  
* [HTTP/2] [1] [:authority: www.google.com]  
* [HTTP/2] [1] [:path: /]  
* [HTTP/2] [1] [user-agent: curl/8.18.0]
```

Figure 8:* Kali test outputs — successful, HTTPS

```
root@kali: ~  
Session Actions Edit View Help  
  
(root@kali)~  
# curl -v -I http://example.com  
* Host example.com:80 was resolved.  
* IPv6: 2606:4700:10::ac42:93f3, 2606:4700:10::6814:179a  
* IPv4: 104.20.23.154, 172.66.147.243  
* Trying [2606:4700:10::ac42:93f3]:80...  
* Immediate connect fail for 2606:4700:10::ac42:93f3: Network is unreachable  
* Trying 104.20.23.154:80...  
* Established connection to example.com (104.20.23.154 port 80) from 192.168.10.101 port 37216  
* using HTTP/1.x  
> HEAD / HTTP/1.1  
> Host: example.com  
> User-Agent: curl/8.18.0  
> Accept: */*  
>  
* Request completely sent off  
< HTTP/1.1 200 OK  
HTTP/1.1 200 OK  
< Date: Wed, 03 Jun 2026 22:13:06 GMT  
Date: Wed, 03 Jun 2026 22:13:06 GMT  
< Content-Type: text/html  
Content-Type: text/html  
< Connection: keep-alive  
Connection: keep-alive  
< Server: cloudflare  
Server: cloudflare  
< Last-Modified: Thu, 28 May 2026 18:39:43 GMT  
Last-Modified: Thu, 28 May 2026 18:39:43 GMT  
< Allow: GET, HEAD  
Allow: GET, HEAD  
< Accept-Ranges: bytes  
Accept-Ranges: bytes  
< Age: 738  
Age: 738  
< cf-cache-status: HIT  
cf-cache-status: HIT  
< CF-RAY: a0620b099d5f5088-AMS  
CF-RAY: a0620b099d5f5088-AMS  
<  
* Connection #0 to host example.com:80 left intact
```

Figure 9: Kali test outputs — successful HTTP

```
root@kali: ~  
Session Actions Edit View Help  
  
(root@kali)~  
# ping -c 4 192.168.10.1  
PING 192.168.10.1 (192.168.10.1) 56(84) bytes of data:  
64 bytes from 192.168.10.1: icmp_seq=1 ttl=64 time=0.341 ms  
64 bytes from 192.168.10.1: icmp_seq=2 ttl=64 time=1.44 ms  
64 bytes from 192.168.10.1: icmp_seq=3 ttl=64 time=1.27 ms  
64 bytes from 192.168.10.1: icmp_seq=4 ttl=64 time=1.80 ms  
  
— 192.168.10.1 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3037ms  
rtt min/avg/max/mdev = 0.341/1.211/1.795/0.536 ms  
  
(root@kali)~  
# nslookup google.com  
Server: 192.168.10.1  
Address: 192.168.10.1#53  
  
Non-authoritative answer:  
Name: google.com  
Address: 192.178.25.238  
Name: google.com  
Address: 2a00:1450:4017:823::200e  
  
(root@kali)~  
# ping -c 4 8.8.8.8  
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:  
  
— 8.8.8.8 ping statistics —  
4 packets transmitted, 0 received, 100% packet loss, time 3128ms  
  
(root@kali)~  
# ss
```

Figure 10: Kali test outputs showing successful intra-LAN ping to 192.168.10.1, successful DNS resolution via the firewall, and blocked external ICMP to 8.8.8.8

```
root@kali: ~  
Session Actions Edit View Help  
  
root@kali:~# timeout 5 nc -zv 1.1.1.1 23  
  
root@kali:~# timeout 5 nc -zv 1.1.1.1 25  
  
root@kali:~# timeout 5 nc -zv 1.1.1.1 21  
  
root@kali:~#
```

Figure 11: Kali nc port tests to 1.1.1.1 on ports 23 (Telnet), 25 (SMTP), and 21 (FTP), All three connections silently timed out, confirming that the LAN Default Deny rule drops disallowed outbound traffic without returning any response.

pfSense

COMMUNITY EDITION

System

Interfaces

Firewall

Services

VPN

Status

Diagnostics

Help

Status / System Logs / Firewall / Normal View

System

Firewall

DHCP

Authentication

IPsec

PPP

PPPoE/L2TP Server

OpenVPN

NTP

Packages

Settings

Normal View

Dynamic View

Summary View

Last 500 Firewall Log Entries. (Maximum 500)

Action	Time	Interface	Rule	Source	Destination	Protocol
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	216.58.204.113:443	192.168.10.101:41394	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	172.217.18.162:443	192.168.10.101:40888	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	142.251.142.110:443	192.168.10.101:46902	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	192.178.24.10:443	192.168.10.101:52868	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	142.251.38.238:443	192.168.10.101:52718	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	142.251.38.227:443	192.168.10.101:45748	TCP:PA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	172.217.20.67:80	192.168.10.101:47896	TCP:FPA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	172.217.20.67:80	192.168.10.101:47910	TCP:FPA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	172.217.20.67:80	192.168.10.101:47912	TCP:FPA
✗	Jun 3 22:34:37	LAN	Default deny rule IPv4 (1000000104)	172.217.20.67:80	192.168.10.101:34438	TCP:FPA

Figure 12: pfSense firewall log showing default-deny block entries

7. Challenges Encountered and Resolutions

Several non-trivial issues were encountered during the lab, The most significant are summarised below.

7.1 Traffic Bypassing the Firewall

Early verification tests appeared to succeed (including ping 8.8.8.8), which contradicted the deny policy. Inspection of the ICMP replies showed TTL=128, indicating a Windows host was responding rather than an external server, The cause was that the Kali client and pfSense WAN were both on VMware's NAT network (VMnet8), so LAN traffic never traversed the firewall.

Resolution: A dedicated host-only network (VMnet2, 192.168.10.0/24)

was created and Kali was moved onto it, forcing all traffic through pfSense.

7.2 Interface Mapping Mismatch

After the topology change, the WAN interface failed to obtain a DHCP lease, FreeBSD's interface naming (em0/em1) did not correspond to VMware's adapter order, so em0 was bound to the NAT network and em1 to the host-only network, the opposite of the intended configuration.

Resolution: Rather than reassigning interfaces inside pfSense (which would have invalidated the existing ruleset), the two VMware network adapters were swapped at the VM settings level, preserving all firewall rules.

7.3 IP Conflict on VMnet2

During final testing, Kali could no longer reach the pfSense LAN gateway despite correct addressing. ARP inspection revealed that the MAC address learned for 192.168.10.1 belonged to the Windows host virtual adapter, not pfSense. VMware had assigned the same IP(192.168.10.1) to its VMnet2 host adapter, causing the host to answer ARP requests faster than the firewall.

Resolution: The VMware host adapter on VMnet2 was disabled, eliminating the conflict and restoring connectivity.

7.4 VMware Service Failures

On two occasions, the VMware NAT service was found stopped after a system restart, preventing the WAN interface from obtaining a DHCP lease.

Resolution: The VMware NAT Service and VMware DHCP Service were configured with startup type "Automatic" to ensure they start with Windows.

8. Conclusion

This lab demonstrated the design and deployment of a pfSense firewall enforcing a default-deny policy with a tightly scoped allowlist for essential services.

The ruleset was validated through a series of allow and deny tests from a Kali client, and all observed outcomes matched the intended policy.

Three principles proved central to the exercise.

First, default-deny is only meaningful if traffic actually traverses the firewall, an early misconfiguration showed how easily a lab can produce false-positive results when the network topology is not verified.

Second, rule order is a security control, not a presentation choice: specific rules must precede broader ones, and explicit catch-all deny rules enable both auditability and logging.

Third, least privilege applies per rule, not only across the ruleset as a whole restricting ICMP to LAN-internal traffic, for example, prevents a permitted protocol from being abused for outbound reconnaissance.

Beyond the technical configuration, the lab reinforced the value of empirical verification.

Several issues, bypass traffic, interface mapping, and an IP conflict caused by a VMware host adapter, would not have been detected without active testing from inside the protected segment.

In a production environment, this corresponds to the practice of regularly validating firewall policy with controlled traffic rather than relying on the ruleset alone.

The completed lab provides a working baseline that can be extended in future work, for example by adding intrusion detection (Snort or Suricata), VPN access for the trusted admin source, or segmentation into multiple internal zones.